

BÁO CÁO BÀI TẬP LỚN

HỆ THỐNG ĐẤU GIÁ TRỰC TUYẾN

Online Auction System

Môn học: Lập Trình Nâng Cao

Giảng viên hướng dẫn: ThS. Nguyễn Thị Hồng

Nhóm sinh viên thực hiện

Đỗ Hải Đăng	25020113
Nguyễn Vũ Sơn	25020352
Lê Quang Nghĩa	25020292
Nguyễn Duy Quang	25020330

Java 21 • JavaFX 21 • MySQL 8+ • HikariCP 5.1 • TCP Socket • JUnit 5 & JaCoCo • Maven 3.9+

Hà Nội, tháng 5 năm 2026

PHẦN 1: GIỚI THIỆU MỤC TIÊU VÀ PHẠM VI THỰC HIỆN

1.1 Mục tiêu dự án

Đồ án "Hệ thống Đấu Giá Trực Tuyến" được xây dựng nhằm vận dụng toàn diện kiến thức môn Lập Trình Nâng Cao vào một sản phẩm phần mềm hoàn chỉnh. Các mục tiêu kỹ thuật cụ thể bao gồm:

- Lập trình hướng đối tượng (OOP): kế thừa Entity → User → Bidder/Seller/Admin và Entity → Item → 9 danh mục sản phẩm (Art, Books, Electronics, Fashion, Furniture, Jewelry, Music, Sports, Vehicle), đa hình qua `getSpecificInfo()`, đóng gói dữ liệu.
- Lập trình giao diện (JavaFX): 18 file FXML thiết kế bằng Scene Builder, tách biệt View–Controller; CSS tùy chỉnh giao diện responsive.
- Lập trình mạng (TCP Socket): kiến trúc Client–Server qua Object Stream, giao thức Message-driven đóng gói bởi MessageFactory, port 8989.
- Lập trình đa luồng: mỗi Client được cấp một ClientHandler thread riêng; `placeBid()` đồng bộ synchronized + Database Transaction atomic COMMIT/ROLLBACK.
- Quản trị cơ sở dữ liệu: MySQL 8+ schema 6 bảng chuẩn hóa, DAO Pattern 7 lớp, HikariCP connection pool (tối đa 10 connections).
- Đảm bảo chất lượng: 115 unit test (JUnit 5, JaCoCo ngưỡng $\geq 30\%$), GitHub Actions CI/CD, OWASP Dependency-Check quét lỗ hổng bảo mật.

1.2 Phạm vi hệ thống

Hệ thống phục vụ ba vai trò người dùng với quyền hạn và chức năng riêng biệt:

- Admin (Quản trị viên): quản lý toàn bộ người dùng (khóa/mở khóa, xóa, lịch sử đấu giá), quản lý vật phẩm, giám sát hệ thống.
- Seller (Người bán): tạo vật phẩm (9 danh mục), tạo và khởi chạy phiên đấu giá, theo dõi tiến trình đấu giá, nhận thanh toán.
- Bidder (Người mua): tìm kiếm phiên đấu giá, đặt giá thủ công hoặc tự động (AutoBid), chat thời gian thực, quản lý watchlist, nạp tiền.

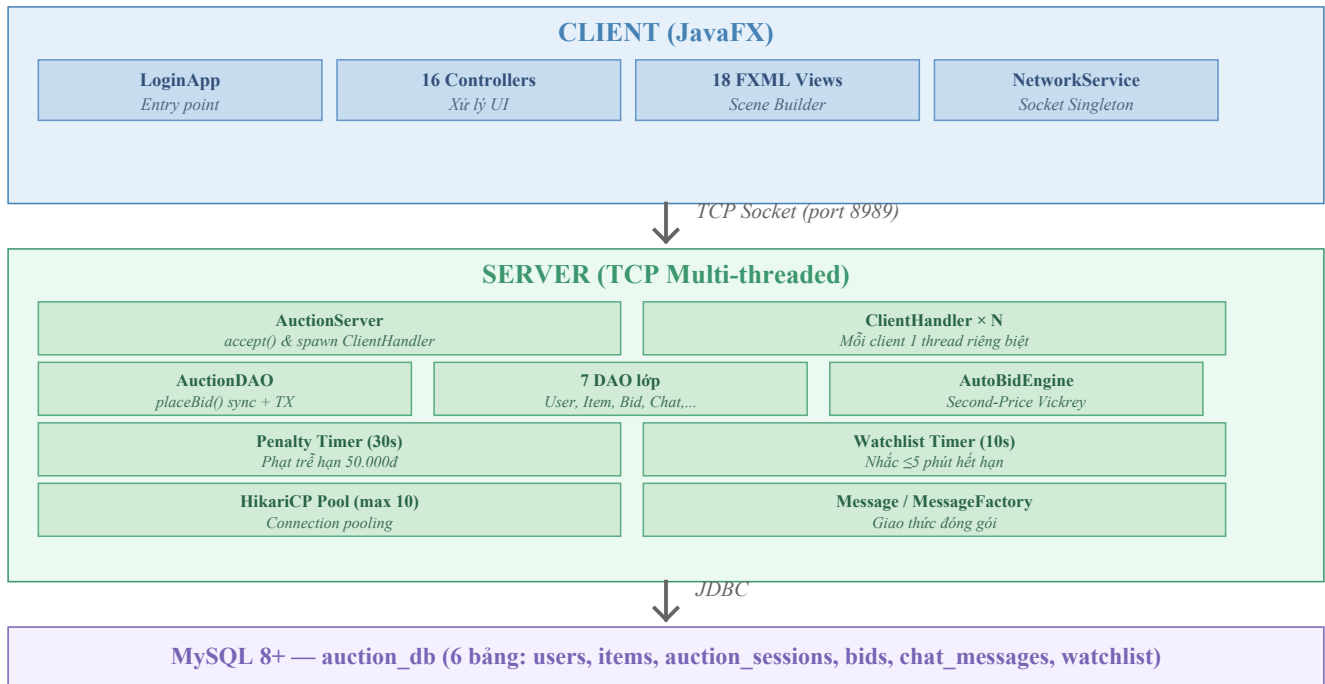
Vòng đời phiên đấu giá gồm 6 trạng thái chuyển tiếp:

- OPEN → RUNNING (Seller khởi động) → PAYMENT_PENDING (hết giờ, có người thắng) → PAID (thanh toán hoàn tất).
- OPEN → RUNNING → FINISHED (kết thúc không có người đặt giá). Bất kỳ trạng thái → CANCELED (Admin hoặc Seller hủy).

Các tính năng thời gian thực nâng cao: AutoBid theo cơ chế Vickrey Second-Price, Sniper Protection tự động gia hạn 2 phút khi có giá mới trong 2 phút cuối, chat trực tiếp theo phòng đấu giá, watchlist tự động nhắc nhở khi phiên sắp kết thúc, và phạt tự động 50.000đ đối với người thắng không thanh toán trong 1 giờ.

PHẦN 2: KIẾN TRÚC TỔNG THỂ CỦA HỆ THỐNG

2.1 Sơ đồ kiến trúc tổng thể



Hình 1. Sơ đồ kiến trúc tổng thể hệ thống — Client (JavaFX) kết nối TCP Socket đến Server đa luồng, DAO layer truy xuất MySQL qua HikariCP connection pool.

2.2 Mô tả kiến trúc

Client Side — JavaFX + NetworkService

Phía Client tổ chức theo mô hình MVC: View (18 FXML) tách biệt với Controller (16 lớp) chỉ xử lý logic hiển thị. NetworkService là Singleton duy trì kết nối TCP Socket đến Server qua ObjectOutputStream/InputStream. Mọi phản hồi từ Server được chuyển lên JavaFX Application Thread bằng Platform.runLater() nhằm tránh nghẽn giao diện. Package Controller/utils (UIUtils, ResponseUtils, FormatUtils, CategoryMapper, AlertUtils, SearchCriteriaBuilder) cung cấp tiện ích dùng chung, giảm trùng lặp mã nguồn.

Server Side — TCP Multi-threaded Server

AuctionServer lắng nghe tại port 8989, mỗi Client kết nối được cấp một ClientHandler (kế thừa Thread) xử lý độc lập. Kiến trúc Message-driven: yêu cầu từ Client được đóng gói thành Message (type, sender, content), Server phân tích và điều phối qua MessageFactory. Các phương thức nghiệp vụ quan trọng (placeBid, finishAuction, processPayment) được bảo vệ bởi synchronized + Database Transaction atomic COMMIT/ROLLBACK, ngăn chặn race condition. Hai TimerTask nền: Penalty Timer (30s) phạt trễ hạn thanh toán, Watchlist Timer (10s) gửi nhắc nhở khi phiên sắp hết hạn.

Database & Data Access Layer — DAO Pattern

MySQL 8+ schema gồm 6 bảng: users, items, auction_sessions, bids, chat_messages, watchlist. HikariCP connection pool (max 10 connections) tối ưu hiệu năng. 7 lớp DAO (UserDAO, ItemDAO, AuctionDAO, AuctionSessionDAO, BidDAO, ChatDAO, WatchlistDAO) triển khai CRUD. DatabaseUtil (Singleton) quản lý pool dùng chung. Các Design Pattern hỗ trợ: Factory (ItemFactory — 9 danh mục, UserFactory — 3 vai trò), Observer (AuctionObserver cập nhật trạng thái thời gian thực), Template Method (Entity.getSpecificInfo() trừu tượng).

PHẦN 3: CÁC CHỨC NĂNG ĐẠT ĐƯỢC THEO BAREM ĐIỂM

Năm chức năng cốt lõi được trình bày kèm hướng giải quyết kỹ thuật và lý do lựa chọn:

1 Đăng nhập & Đăng ký bảo mật (PBKDF2 + Salt)

Mật khẩu được hash bằng PBKDF2WithHmacSHA256 (65.536 vòng lặp, salt ngẫu nhiên 16 byte), lưu dạng hex 64 ký tự. Hệ thống tự động phát hiện và nâng cấp mật khẩu SHA-256 cũ lên PBKDF2 khi người dùng đăng nhập (cơ chế migrate tự động). REGISTER mặc định chỉ tạo RegularUser; Admin chỉ tạo qua seedDefaultAdmin() lúc khởi động Server — chặn leo thang đặc quyền. Xác thực 3 lớp: kiểm tra thông tin đăng nhập → trạng thái khóa → quyền truy cập.

→ PBKDF2 với 65.536 vòng lặp khiến tấn công brute-force/rainbow table trở nên bất khả thi. Cơ chế migrate tự động đảm bảo tương thích ngược với dữ liệu cũ mà không cần can thiệp thủ công. Giới hạn REGISTER chỉ tạo user thường loại bỏ vector leo thang đặc quyền phổ biến trong các hệ thống web. Ba lớp xác thực độc lập triển khai nguyên lý defense in depth.

2 Đặt giá thời gian thực & Giải quyết Race Condition

placeBid() được bảo vệ bởi synchronized trên AuctionDAO — chỉ 1 thread thực thi tại một thời điểm. Toàn bộ quy trình kiểm tra (trạng thái phiên, thời gian, số dư, giá hợp lệ, chặn seller tự đấu giá) và ghi dữ liệu (INSERT bid, UPDATE current_price, UPDATE highest_bidder) được bọc trong Transaction với COMMIT/ROLLBACK. Nếu bất kỳ bước nào thất bại, toàn bộ transaction rollback, đảm bảo dữ liệu nhất quán tuyệt đối.

→ Trong môi trường đa luồng với hàng chục ClientHandler đồng thời, thiếu synchronized + transaction, hai người dùng đặt giá cùng mili-giây có thể cùng được ghi nhận thắng — gây sai lệch nghiêm trọng. Giải pháp synchronized tăng ứng dụng + transaction tăng DB tạo hàng rào kép, đảm bảo tính ACID của từng lượt đặt giá.

3 Tính năng Tự động trả giá — AutoBid (Vickrey Second-Price)

Người dùng thiết lập maxAmount; AutoBidEngine trên Server tự động đặt giá khi có người khác trả cao hơn. Mỗi bước = currentPrice + minIncrement, không vượt maxAmount. Cơ chế Vickrey Second-Price: người thắng chỉ trả mức giá của người thua cao nhất + một bước giá, không phải toàn bộ maxAmount. Danh sách AutoBid được bảo vệ bởi synchronized(autoBidLock). Engine tự động dừng khi hết tiền hoặc đạt maxAmount.

→ AutoBid giải phóng người dùng khỏi việc liên tục theo dõi. Cơ chế Second-Price (Vickrey) là tiêu chuẩn công nghiệp (eBay, Google Ads) — khuyến khích đặt giá đúng mức sẵn sàng chi trả thực, tối ưu cả trải nghiệm người dùng lẫn doanh thu cho người bán. Xử lý trên Server đảm bảo AutoBid hoạt động ngay cả khi Client offline.

4 Tính năng Chống bắn tỉa — Sniper Protection

Khi có lượt đặt giá hợp lệ trong vòng 2 phút cuối (secondsRemaining > 0 && < 120), hệ thống tự động gia hạn endTime thêm 2 phút. Cơ chế kích hoạt trong placeBid(), broadcast thông báo tới tất cả Client trong phòng qua BROADCAST_CHAT. Không giới hạn số lần gia hạn — miễn còn đặt giá mới trong 2 phút cuối, phiên tiếp tục được kéo dài.

→ Chống chiến thuật "sniping" (đặt giá giây cuối bằng bot khiến người thật không kịp phản ứng) — vấn đề nhức nhối trên các sàn đấu giá thực tế. Gia hạn tự động đảm bảo mọi người tham gia có cơ hội phản hồi công bằng, đồng thời tăng giá trị thu được cho người bán thông qua cạnh tranh lành mạnh.

5 Scheduler chạy nền — Phạt thanh toán & Thông báo Watchlist

Hai TimerTask độc lập: (1) Penalty Timer (30s) quét PAYMENT_PENDING quá hạn 1 giờ, tự động phạt người thắng 50.000đ và hủy phiên; (2) Watchlist Timer (10s) duyệt watchlist toàn hệ thống, nếu phiên còn ≤ 5 phút sẽ kết thúc, broadcast nhắc nhở BROADCAST_WATCHLIST. Cả hai chạy hoàn toàn trên Server, không yêu cầu Client online.

→ Xử lý tập trung trên Server đảm bảo công bằng và nhất quán — không phụ thuộc Client có đang mở ứng dụng hay không. Cơ chế timer chủ động loại bỏ polling từ Client (gây tải hệ thống và tiêu tốn băng thông), đảm bảo thời gian phản hồi nhanh, chính xác cho các sự kiện quan trọng.

PHẦN 4: PHÂN CHIA CÔNG VIỆC TRONG NHÓM

Dự án hoàn thiện với 128 commit qua GitHub, công việc được phân chia theo module kỹ thuật:

STT	Thành viên	MSSV	Công việc đảm nhiệm
1	Đỗ Hải Đăng	25020113	Thiết kế Model (Entity, User, Item + 9 subclass), cài đặt Factory Pattern (ItemFactory, UserFactory), viết 115 Unit Test (JUnit 5, JaCoCo).
2	Nguyễn Vũ Sơn	25020352	Phát triển TCP Server (AuctionServer, ClientHandler), giao thức Message/MessageFactory, đồng bộ đa luồng, thiết kế MySQL schema (6 bảng).
3	Lê Quang Nghĩa	25020292	Thiết kế giao diện JavaFX (18 FXML + CSS), 16 Controller phía Client, xử lý tương tác UI bất đồng bộ (Platform.runLater).
4	Nguyễn Duy Quang	25020330	placeBid() đồng bộ, AutoBidEngine (Second-Price), Sniper Protection (gia hạn 2 phút), Scheduler (Penalty + Watchlist Timers).

Bảng 1. Phân công công việc chi tiết theo module kỹ thuật của từng thành viên.

4.1 Thống kê dự án

Module	Main (LOC)	Test (LOC)	Số file	Số test
Model	~1.800	—	22	—
Controller	~3.500	—	23	—
DAO	~1.600	—	8	—
Network	~2.200	—	7	—
Factory/Service	~800	—	6	—
Exception/Util	~600	—	9	—
Unit Tests	—	~1.900	7	115
Tổng cộng	~12.000	~1.900	~80	115

Bảng 2. Thống kê quy mô dự án theo từng module — tổng ~12.000 LOC chính, 115 bài kiểm thử đơn vị.

Hệ thống được tích hợp CI/CD qua GitHub Actions: build Maven tự động, kiểm thử JUnit + JaCoCo (ngưỡng bao phủ dòng lệnh $\geq 30\%$, loại trừ Controller/Network do phụ thuộc giao diện), phân tích chất lượng mã nguồn Qodana, và quét lỗ hổng bảo mật OWASP Dependency-Check (ngưỡng CVSS ≥ 8). Các Design Pattern được áp dụng: Singleton (DatabaseUtil, NetworkService), Factory (ItemFactory 9 danh mục, UserFactory 3 vai trò), DAO (7 lớp), Observer (AuctionObserver), Template Method (Entity.getSpecificInfo()). Bảo mật được thiết kế theo defense in depth: 3 lớp kiểm soát truy cập (FXML visibility + Controller guard + Server isAdmin() check), PBKDF2 hash mật khẩu, PreparedStatement chống SQL injection, và seed admin duy nhất chặn leo thang đặc quyền.